

Scan to enter site  
[www.ktunotes.in](http://www.ktunotes.in)



Get it on play store  
[bit.ly/ktunotesapp](https://bit.ly/ktunotesapp)



The logo for KTUnotes, featuring a stylized yellow and orange circular graphic to the right of the text.  
**KTUnotes**  
The learning companion.



[mail@ktunotes.in](mailto:mail@ktunotes.in)

30/11/19  
wed.

# MODULE 1

## Introduction to Security

- Confidentiality
- Integrity
- Availability

The field of network and internet security consists of measures to deter, prevent, detect and correct security violations that involve the transmission of information.

→ Computer Security is defined as the protection afforded to an automated information system in order to attain the objectives of preserving integrity, availability & confidentiality of information system resources. These definitions introduce 3 key objectives for all of security.

## Security Goals

It can be classified as

- 1) Confidentiality
- 2) Integrity
- 3) Availability

## CONFIDENTIALITY

It is the protection against unauthorised disclosure.

It covers data confidentiality assures that private or confidential information is not made available or disclosed to unauthorised individuals.

- Privacy Concerns that individuals control or influence what information related to them may be collected and stored by whom and to whom that information may be disclosed.

## INTEGRITY

The assurance that the data received is exactly as sent by an authorised entity i.e., contains no modification, insertion, deletion or replay. Any required modification to the data should only be done by authorised entities through authorised mechanisms. Integrity covers data integrity and system integrity.

## AVAILABILITY

The information created and stored by an organisation needs to be available to authorised entities. The unavailability of information can be just as harmful as the lack of Confidentiality or Integrity.

## OSI Security Architecture

ITU-T X 800, OSI Security architecture is useful way of organising the task of providing security. It provides a systematic approach to assess the security needs of an organisation and to evaluate and choose various security products and policies and approaches to satisfy those requirements.

→ ITU-T X 800 focus on Security attack, Security Services & Security mechanisms

# Security Attacks

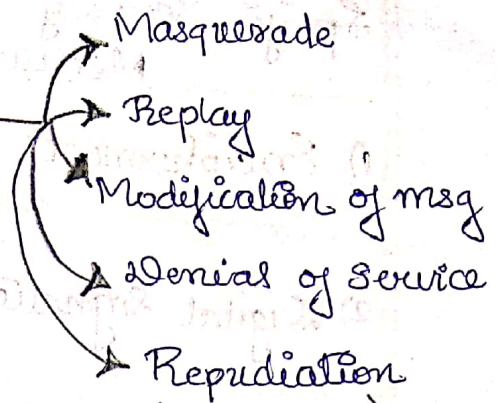
## Two Types

→ Active

→ Passive

→ Traffic analysis

Release of msg content



"At origin" "At destination"

if sender or receiver say they have not send or received msg

Peer Entity authentication

Data Origin authentication

## Security Services

1. Authentication.

2. Access Control.

3. Confidentiality

Connection confidentiality (path established)

Connectionless confidentiality

Selected field confidentiality

Traffic flow confidentiality (communication follow for long time)

4. Data Integrity

Connection integrity with recovery

" " without recovery

Selected field connection Integrity

Connection less integrity (data send at that moment only)

Selective field connectionless integrity (for selected field)

5. Non Repudiation

## Security Mechanisms

how security measures can be implemented

Two types for specific layers of protocol

Common Security Mechanisms

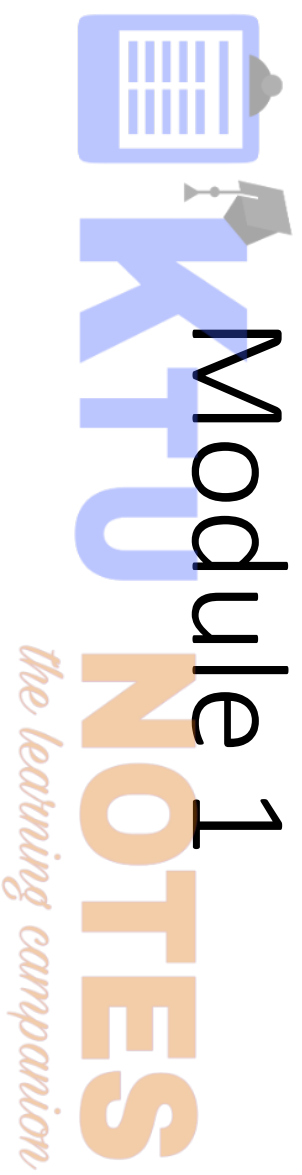
### Specific Security Mechanisms

- 1) Encipherment  
(Encryption, decryption)
- 2) Digital Signature  
(transmission of msg)
- 3) Access Control
- 4) Data Integrity
- 5) Authentication Exchange
- 6) Traffic Padding
- 7) Routing Control  
(alternative path)
- 8) Non-repudiation  
(help from a 3rd person)  
Eg: key distribution Sender

### Pervasive Security Mechanisms

- 1) Trusted functionality  
(already proved)
- 2) Security label  
label diff security present
- 3) Event detection
- 4) Security audit-trail  
check the function properly
- 5) Security recovery  
retrieve back data

**NOTES**  
the learning companion



# Module 1

For more visit [www.ktunotes.in](http://www.ktunotes.in)

# What is Computer Security?

- Computer Security: The protection afforded to an automated information system in order to attain the applicable objectives of **preserving the integrity, availability, and confidentiality of information system resources** (includes hardware, software, firmware, information/data, and telecommunications).
- This definition introduces three key objectives that are at the heart of computer security:

1. Confidentiality
2. Integrity
3. Availability

*the learning companion*

- **Confidentiality:** Preserving **authorized restrictions on information access** and disclosure, including means for protecting personal privacy and proprietary information.
- A loss of confidentiality is the unauthorized disclosure of information.
- **Integrity:** Guarding against **improper information modification** or destruction, including ensuring information nonrepudiation and authenticity.
- A loss of integrity is the unauthorized modification or destruction of information.
- **Availability:** Ensuring **timely and reliable access** to and use of information.
- A loss of availability is the disruption of access to or use of information or an information system.

- **Confidentiality:** This term covers two related concepts:
  - **Data confidentiality:** Assures that private or confidential information is not made available or disclosed to unauthorized individuals.
  - **Privacy:** Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.
- **Integrity:** This term covers two related concepts:
  - **Data integrity:** Assures that information and programs are changed only in a specified and authorized manner.
  - **System integrity:** Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.
- **Availability:** Assures that systems work promptly and service is not denied to authorized users.

# Examples

- **Confidentiality**

- In the military, concealment of sensitive information is a major concern
- In industry, hiding some information is crucial
- In banking, customers account need to be kept secret

- **Integrity**

- In a bank, when a customer deposits or withdraws money, the balance of her account need to be changed

- **Availability**

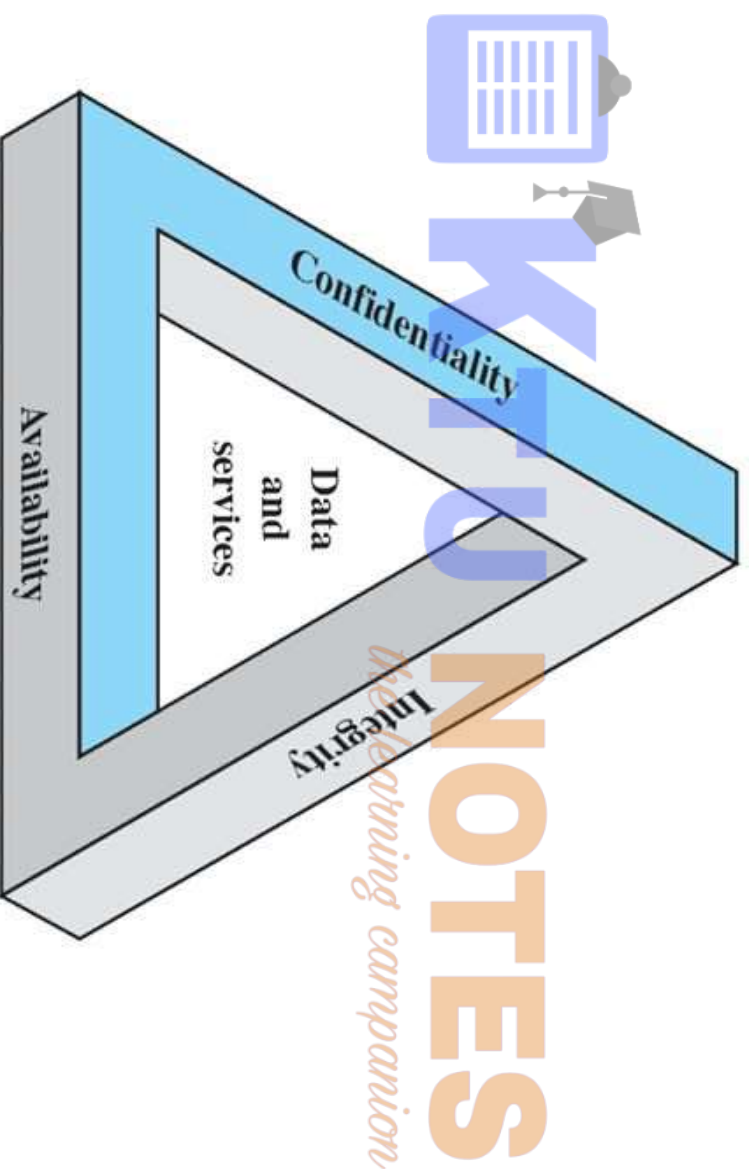
- In a bank, if a customer could not access their accounts for transactions



# The Need for Security

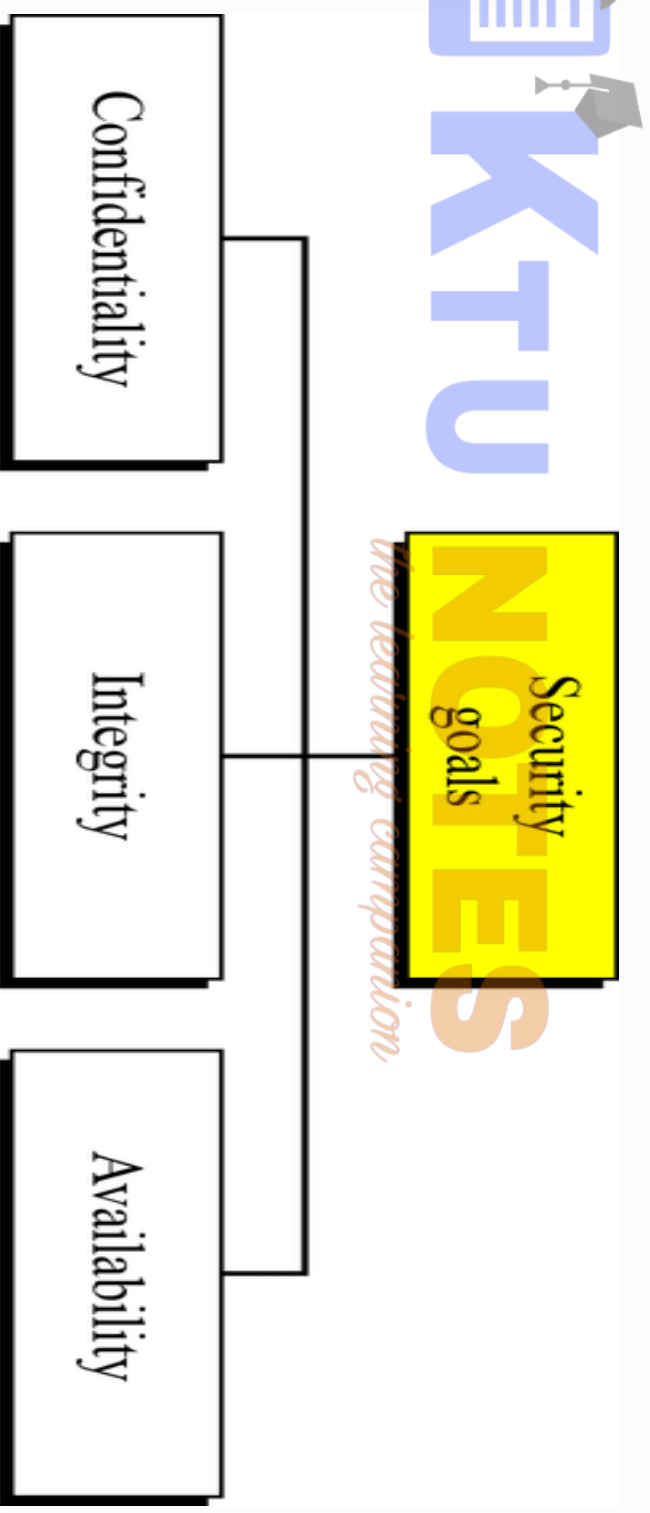
1. **Computer security**-secure the information inside the computer.
2. **Network Security**-secure information in the distributed system.
3. **Internet Security** - measures to protect data during their transmission over a collection of interconnected networks.

# The Security Requirements Triad



# Objectives or Security Goals

1. Confidentiality
2. Integrity
3. Availability





# Aspects of Network Security

- ITU-T Recommendation X.800 “Security Architecture for OSI” describes network security in three aspects:
- **Security attack**
  - Any action that **compromises the security** of information owned by an organization.
- **Security services**
  - That **enhances the security** of the data processing systems and the information transfers of an organization.
- **Security mechanism**
  - A mechanism that is designed to detect, **prevent**, or recover **from a security attack**

NOTES  
*the learning companion*



# Security Attacks

- Any action that compromises the security of information owned by the organization is called as Security Attacks

- **Passive attacks**

- eavesdropping on or monitoring of transmissions
  1. Release of message contents
  2. Traffic analysis

- **Active attacks**

- modification of the data stream or creation of a false stream
  1. Masquerade
  2. Replay
  3. Modification of message
  4. Repudiation
  5. Denial of service

**KTU NOTES**  
*the learning companion*



# Passive attacks

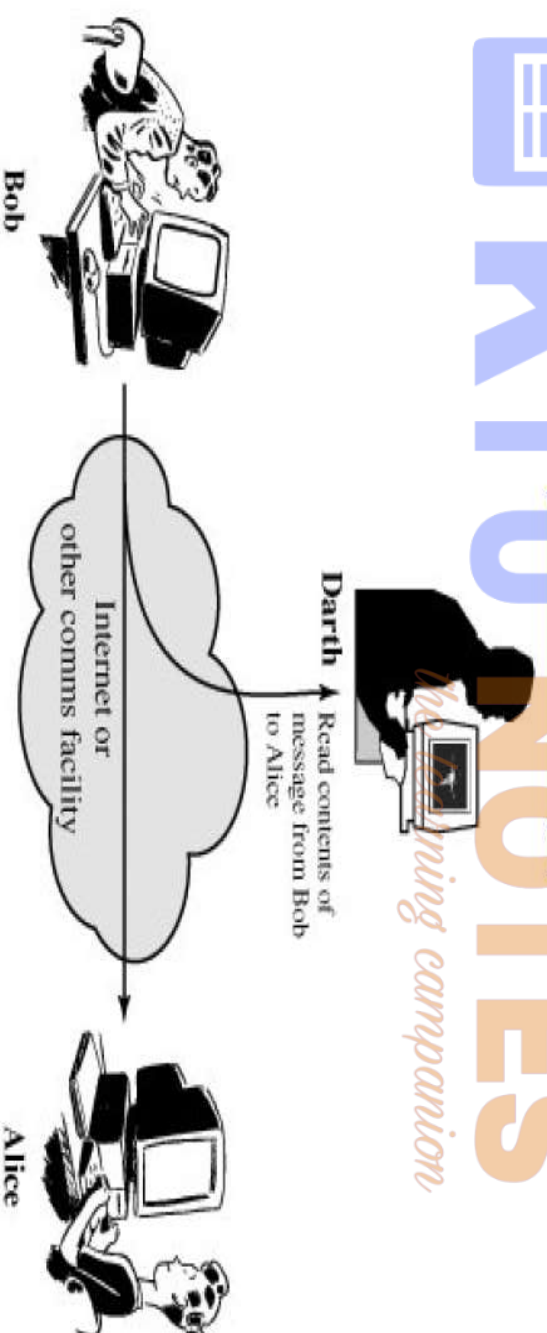
- Eavesdropping on or monitoring of transmissions
- Reading contents of messages
- Difficult to detect passive attacks

- Types

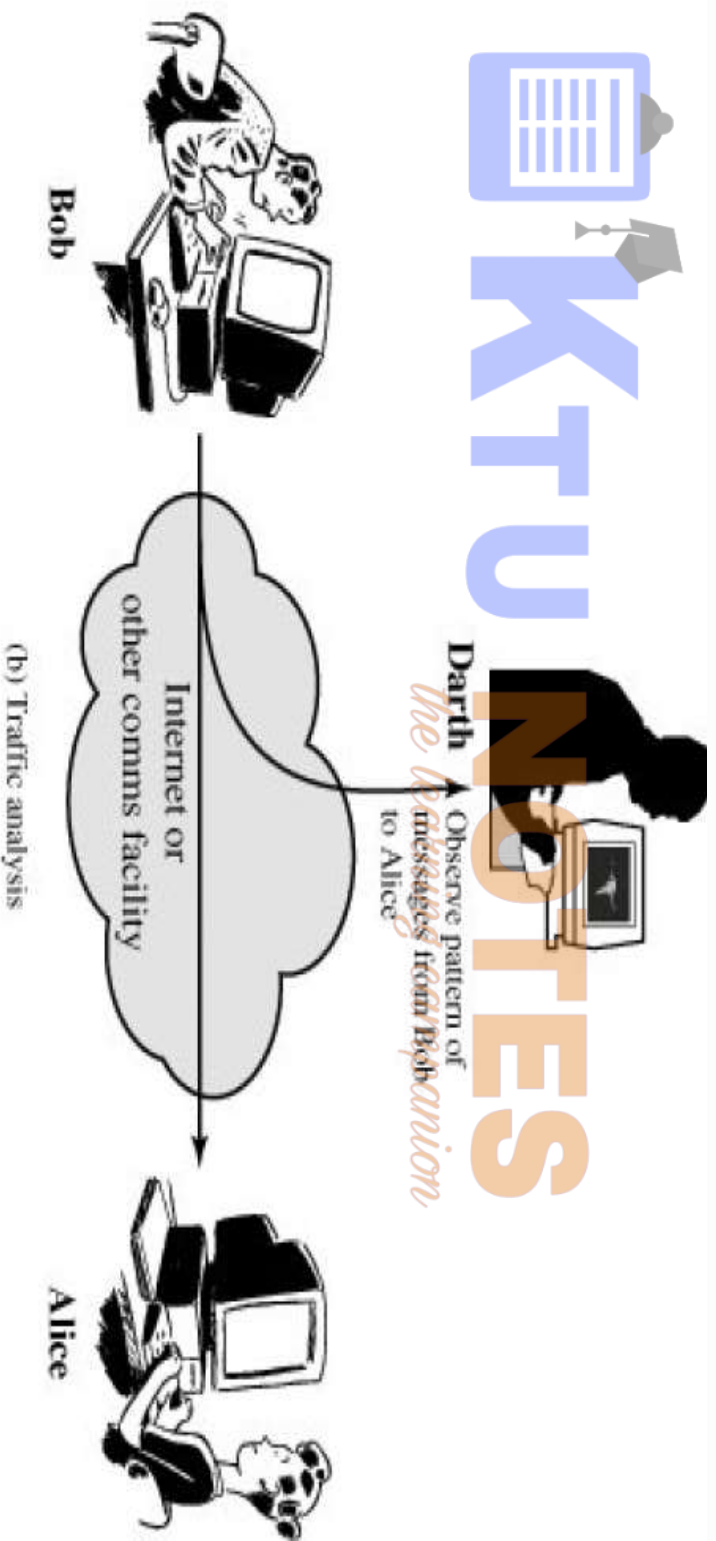
- 1) Release of message contents
- 2) Traffic analysis



- ### 1) Release of message contents/ Snooping
- Snooping refers to unauthorized access to or interception of data.
  - A telephone conversation, an electronic mail message, and a transferred file may contain sensitive or confidential information.
  - An unauthorized entity may intercept the transmission and use the content for his own benefit.
  - To prevent snooping, data can be made non-intelligible to the interceptor using encipherment techniques.

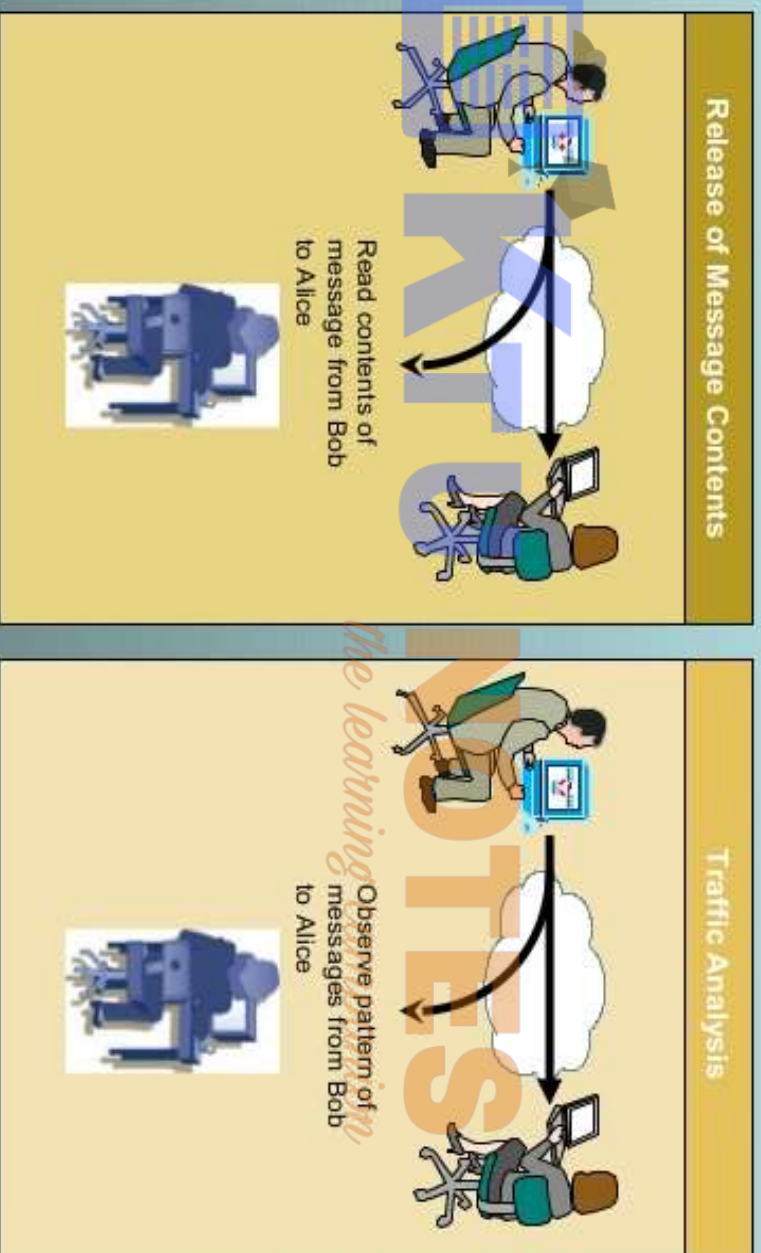


- ## 2. Traffic analysis
- Suppose that we had a way of masking the contents of messages or other information traffic so that opponents, even if they captured the message, could not extract the information from the message.
  - He can obtain some other type information by monitoring online traffic.



# Types of Passive Attack

## Passive Attack





# Active attacks

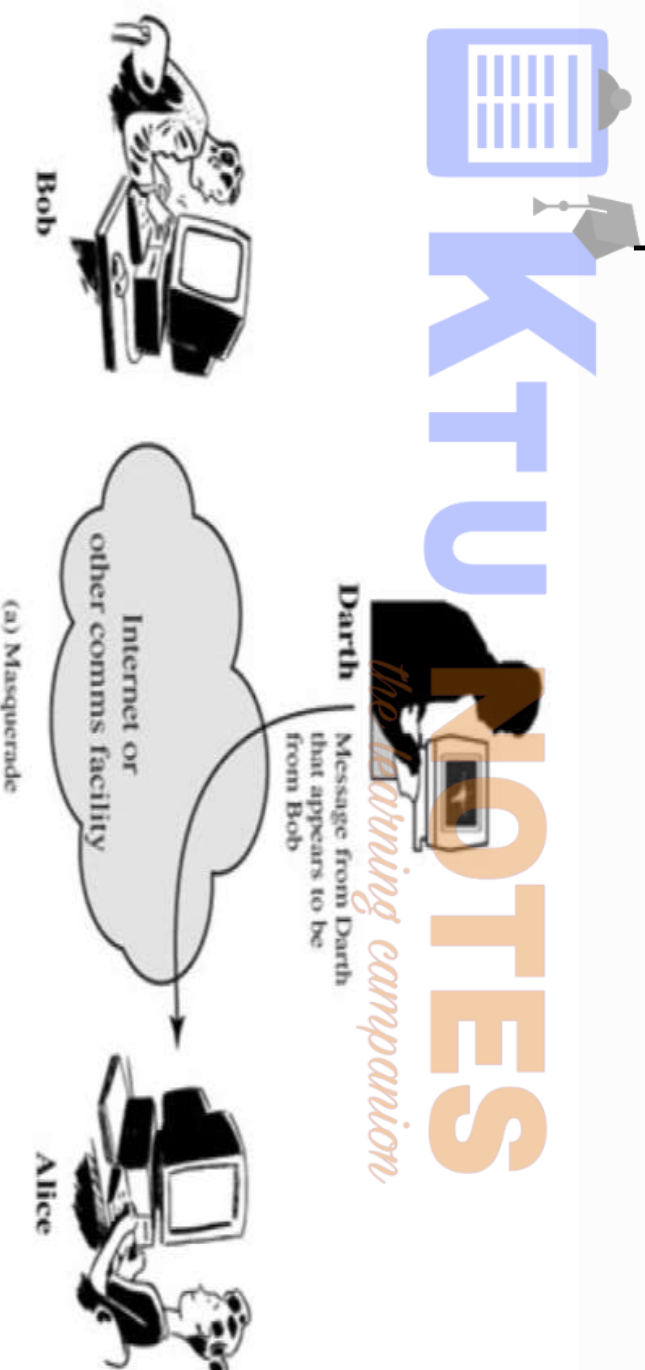
- May change the data or harm the system
- modification of the data stream or creation of a false stream
- Easier to detect than passive attacks because attacker can launch them in variety of ways

- Types

1. Masquerade
2. Replay
3. Modification of message
4. Repudiation
5. Denial of service

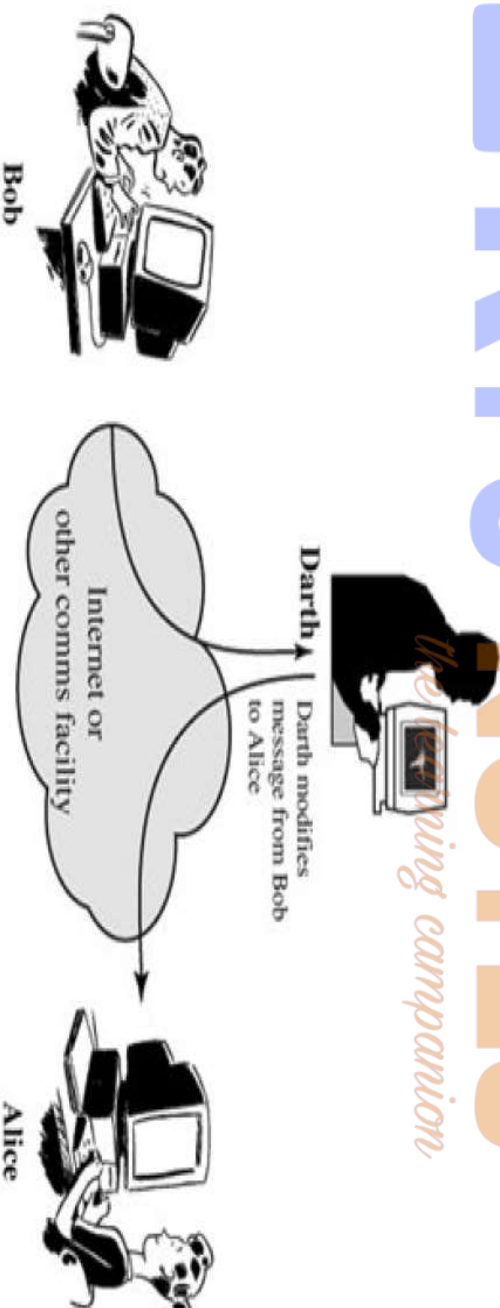
# Masquerade

- A **masquerade** takes place when one entity pretends to be a different entity.
- For eg. An attacker might steal the Pan card and PIN of the bank customer and pretend that she is the customer



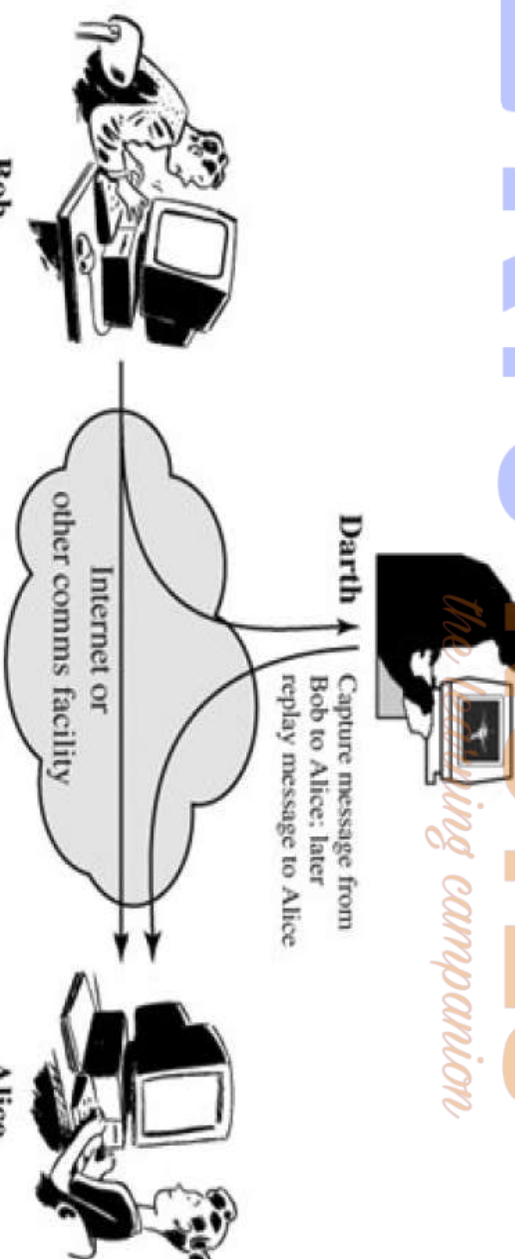
# Modification of messages

- **Modification of messages** simply means that some portion of a legitimate message is altered, or that messages are delayed or reordered, to produce an unauthorized effect.
- For eg. A customer send a message to the bank to do some transaction. The attacker intercept she message and change the type of transaction to benefit herself.



# Replay

- The attacker obtains the copy of the message sent by the user and later tries to replay it.
- For eg. A person sends a request to her bank to ask for payment to the attacker, who has done a job for her. The attacker intercepts the message and send it again to receive another payment from the bank.





# Repudiation

- This type of attack is different from others because it is performed by one of the two parties in the communication: sender or the receiver.
- The sender of the message might later deny that she has sent the message; the receiver of the message might later deny that he has received the message.

- For eg.

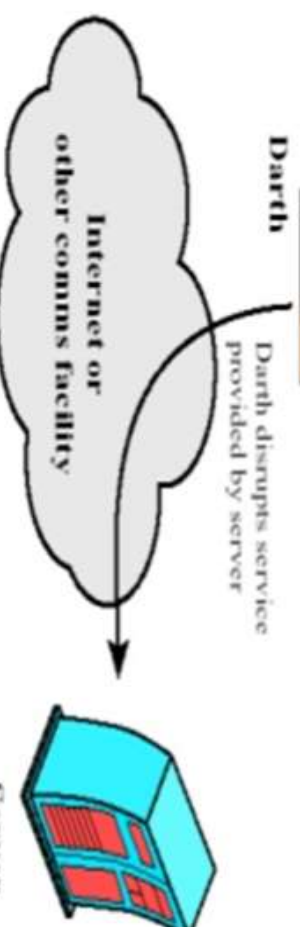
*the learning companion*

- Denial by sender, a bank customer asking her bank to send some money to a third party but later deny that he has made such a request.
- Denial by receiver, a person buy a product and pays for it electronically, but the manufacturer later denies having received the payment.

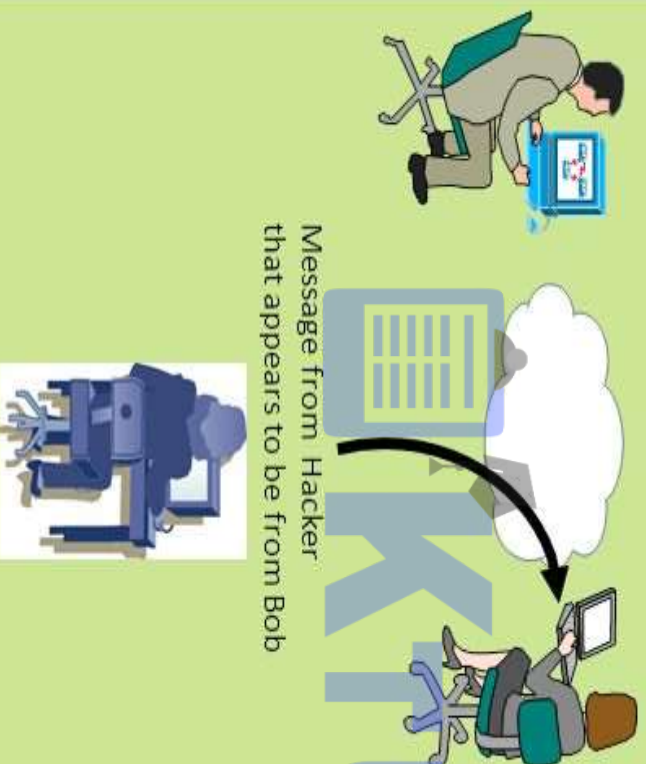
# Denial of service

- The **denial of service** prevents or inhibits the normal use or management of communications facilities.
- service denial is the disruption of an entire network, either by disabling the network or by overloading it with messages so as to degrade performance.
- For eg
  - Attacker send so many requests to server that the server crashes because of heavy load.
  - The attacker might intercept and delete a server's response to a client, making the client believe that the server is not responding.
  - The attacker may also intercepts requests from the client, causing the client to send request many times and overload the system.

*the learning companion*



### Masquerade

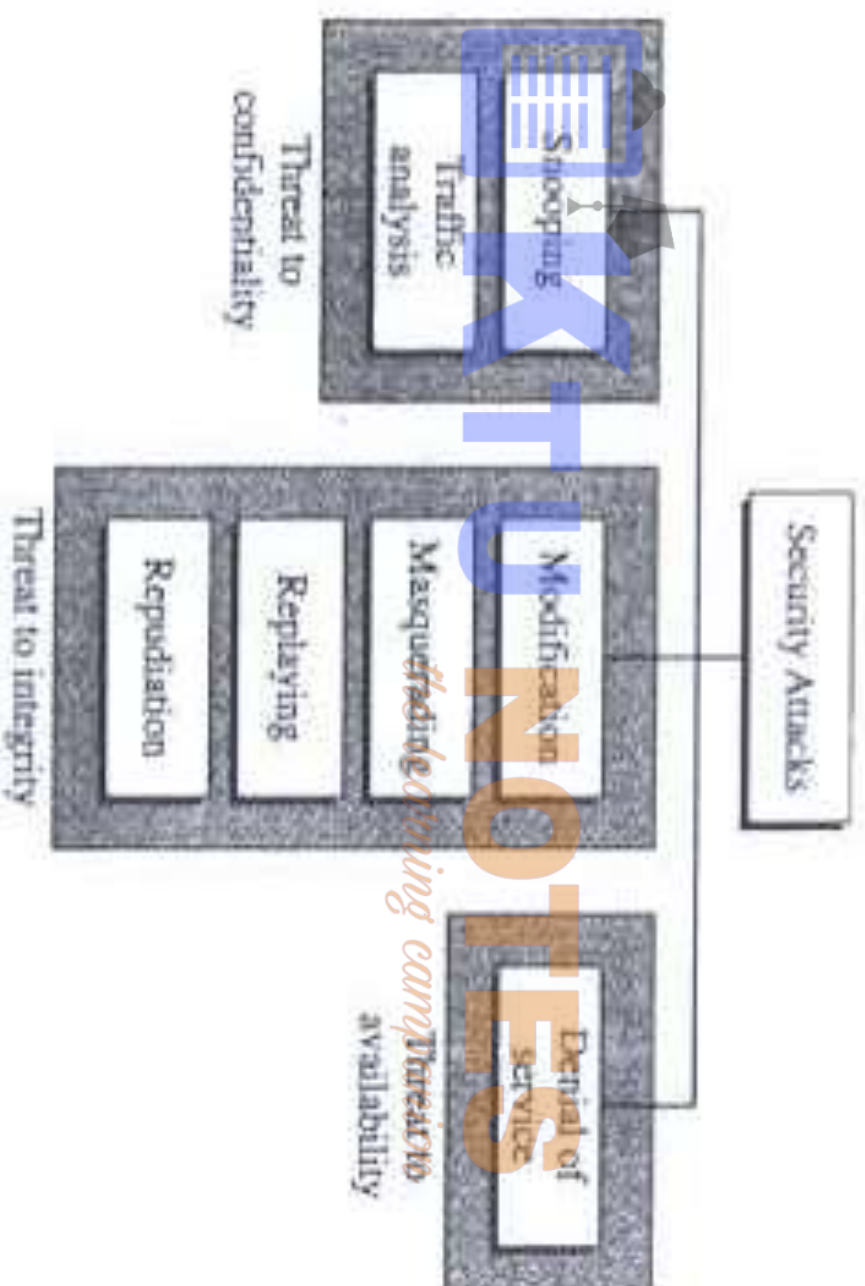


### Replay\*



\* An attack in which a service already authorized and completed is forged by another "duplicate request" in an attempt to repeat authorized commands.

# Security attacks



# Categorization of passive and active attacks

| Attacks           | Passive/Active | Threatening     |
|-------------------|----------------|-----------------|
| Snooping          | Passive        | Confidentiality |
| Traffic Analysis  | Passive        | Confidentiality |
| Modification      | Active         | Integrity       |
| Masquerading      | Active         | Integrity       |
| Replaying         | Active         | Integrity       |
| Repudiation       | Active         | Integrity       |
| Denial of Service | Active         | Availability    |

# Security Services

- ITU-T has defined five services related to the security goals and attacks

1. Data Confidentiality
2. Data Integrity
3. Authentication
4. Non repudiation
5. Access control

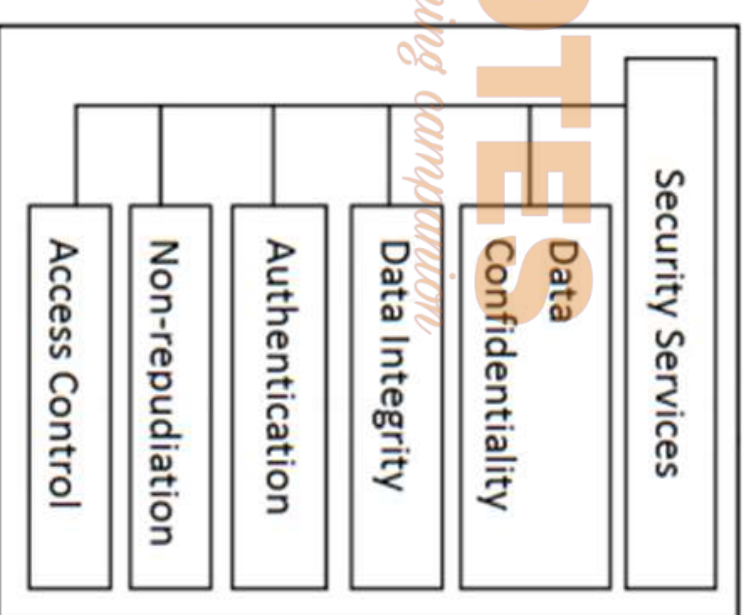
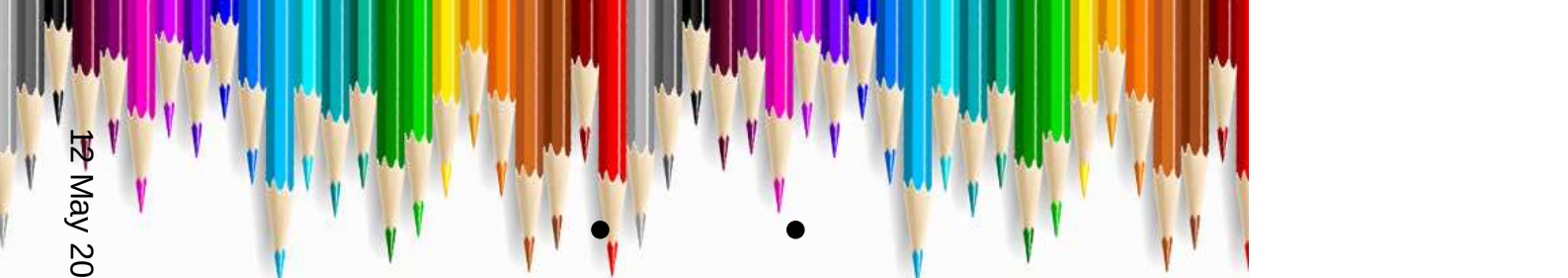


Fig. 3: Security Services



# Authentication

- **To verify the identity of the user/computer**
- Entity authentication provides checking of a claimed identity at a point in time.
  - **Peer entity authentication:** In connection-oriented communication, it provides **authentication of the sender or receiver** during the connection establishment.
  - **Data origin authentication:** In connectionless communication, it **authenticates the source of the data**.



# Access Control

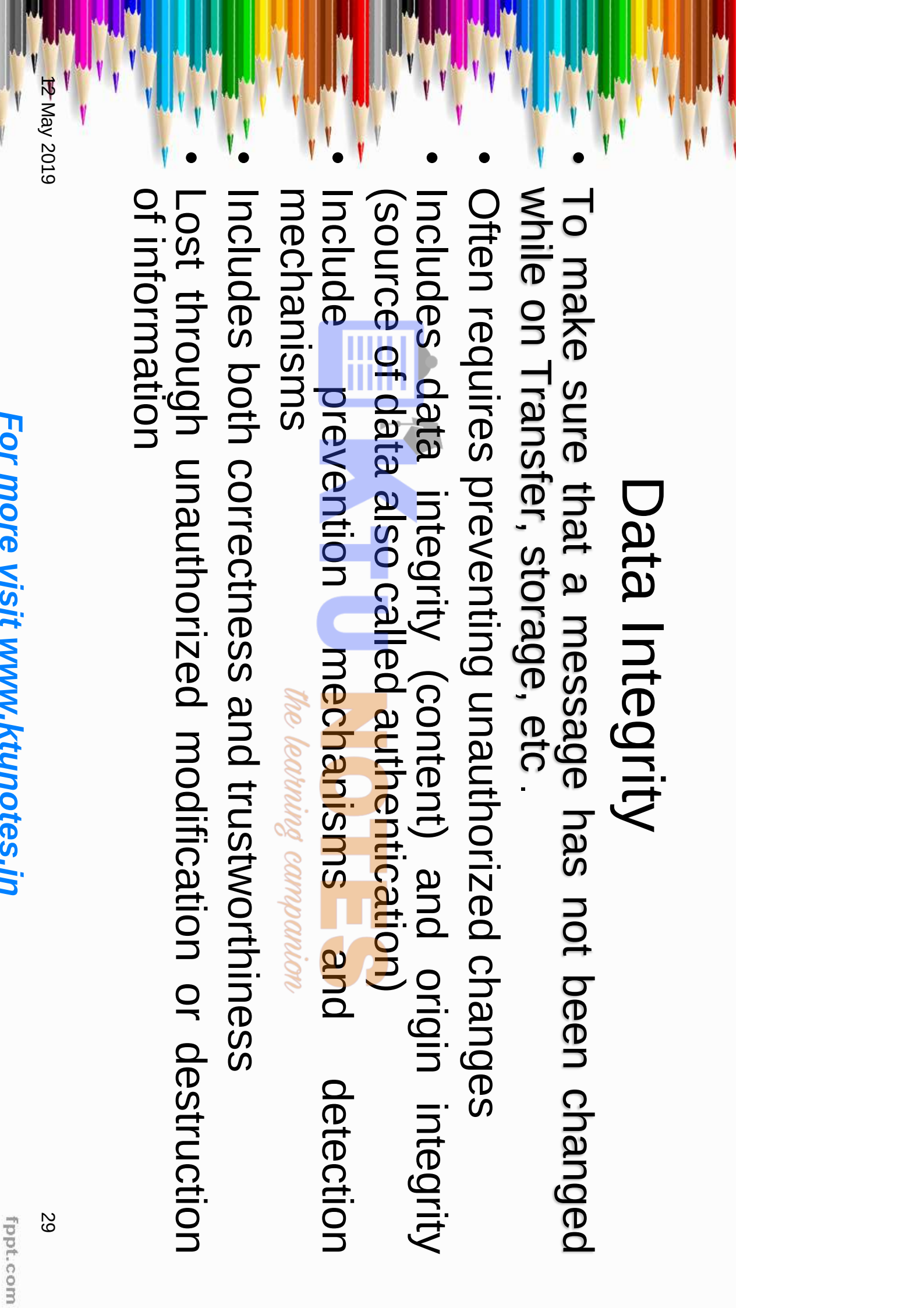
- To be able to tell **who can do what with which resource**
- Provides protection against unauthorized use of resource, including:
  - use of a communications resource
  - reading, writing or deletion of an information resource
  - execution of a processing resource.



# Data Confidentiality

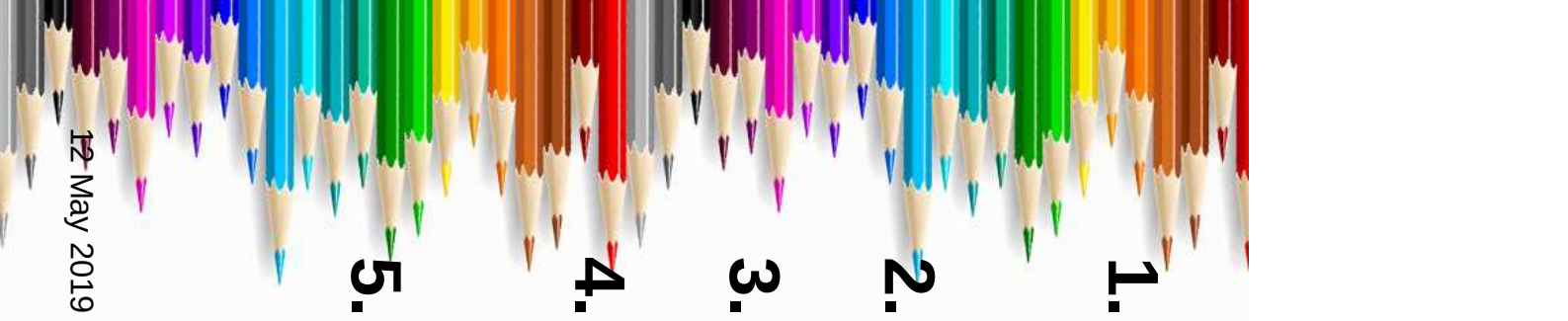
- To keep a message **secret** to those that are not **authorized to read it**
- Protection against unauthorized disclosure of information.
- Four types:
  - Connection confidentiality
  - Connectionless confidentiality,
  - Selective field confidentiality,
  - Traffic flow confidentiality.

- 
1. **Connection confidentiality.**
    - This service provides for the confidentiality of all user data transferred using a connection.
  2. **Connectionless confidentiality.**
    - This service provides for the confidentiality of all user data transferred in a single connectionless data unit (i.e. a packet).
  3. **Selective field confidentiality**
    - This service provides for the confidentiality of selected fields within user data transferred in either a connection or a single connectionless data unit.
  4. **Traffic flow confidentiality**
    - This service provides for the confidentiality of information which might be derived from observation of traffic flows.



# Data Integrity

- To make sure that a message has not been changed while on Transfer, storage, etc .
- Often requires preventing unauthorized changes
- Includes data integrity (content) and origin integrity (source of data also called authentication)
- Include prevention mechanisms and detection mechanisms
- Includes both correctness and trustworthiness
- Lost through unauthorized modification or destruction of information

- 
1. **Connection Integrity with recovery**- Integrity for all user data on connection and detect any modification and within entire data sequence with recovery.
  2. **Connection Integrity without recovery**-only detection without recovery
  3. **Selective field connection integrity**-integrity for selected data field with in the user data for data block
  4. **Connectionless Integrity**-integrity of single connectionless data block and may take the form of detection of data modification
  5. **Selective field Connectionless integrity** -integrity of single connectionless selected data data block and may take the form of detection of data modification



# Non Repudiation

- To make sure that a user/server can't deny later having participated in a transaction
1. non-repudiation of origin
    - Protects against a **sender of data denying** that data was sent.
  2. non-repudiation of destination
    - Protects against a **receiver of data denying** that data was received.

| Service and definition                                                                                                           |  | Specific tasks                                                                                                                                                                                                                                                                       |
|----------------------------------------------------------------------------------------------------------------------------------|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Data Confidentiality - Protection of data from unauthorized disclosure                                                           |  | <ol style="list-style-type: none"> <li>1. Connection confidentiality</li> <li>2. Connectionless confidentiality</li> <li>3. Selective field confidentiality</li> <li>4. Traffic flow confidentiality</li> </ol>                                                                      |
| Data Integrity - Assurance that data is as sent by authorized entity (contains no modifications, insertion, deletion, or replay) |  | <ol style="list-style-type: none"> <li>1. Connection integrity with recovery</li> <li>2. Connection integrity without recovery</li> <li>3. Selective field connection integrity</li> <li>4. Connectionless integrity</li> <li>5. Selective field connectionless integrity</li> </ol> |
| Authentication - Assurance that communicating entity is the one that it claims to be                                             |  | <ol style="list-style-type: none"> <li>1. Peer entity authentication</li> <li>2. Data origin authentication</li> </ol>                                                                                                                                                               |
| Non repudiation - provides protection against one of the entities from denying all or part of the communication                  |  | <ol style="list-style-type: none"> <li>1. Non repudiation of origin</li> <li>2. non repudiation of destination</li> </ol>                                                                                                                                                            |
| Access Control - Prevention of unauthorized use of a resource                                                                    |  |                                                                                                                                                                                                                                                                                      |



# Security mechanisms

- feature designed to detect, prevent, or recover from a security attack
- No single mechanism that will support all Services required
- list of the security mechanisms defined in X.800.
- The mechanisms are divided into those that are implemented in a specific protocol layer, such as TCP or an application-layer protocol, and those that are not specific to any particular protocol layer or security service.
- These mechanisms are called
  - specific security mechanisms and
  - Pervasive security mechanism.

- specific security mechanisms:

1. Encipherment,
2. digital signatures,
3. access controls,
4. data integrity,
5. authentication exchange,
6. traffic padding,
7. routing control,
8. notarization

- pervasive security mechanisms:

1. Trusted functionality,
2. security labels,
3. event detection,
4. security audit trails,
5. security recovery

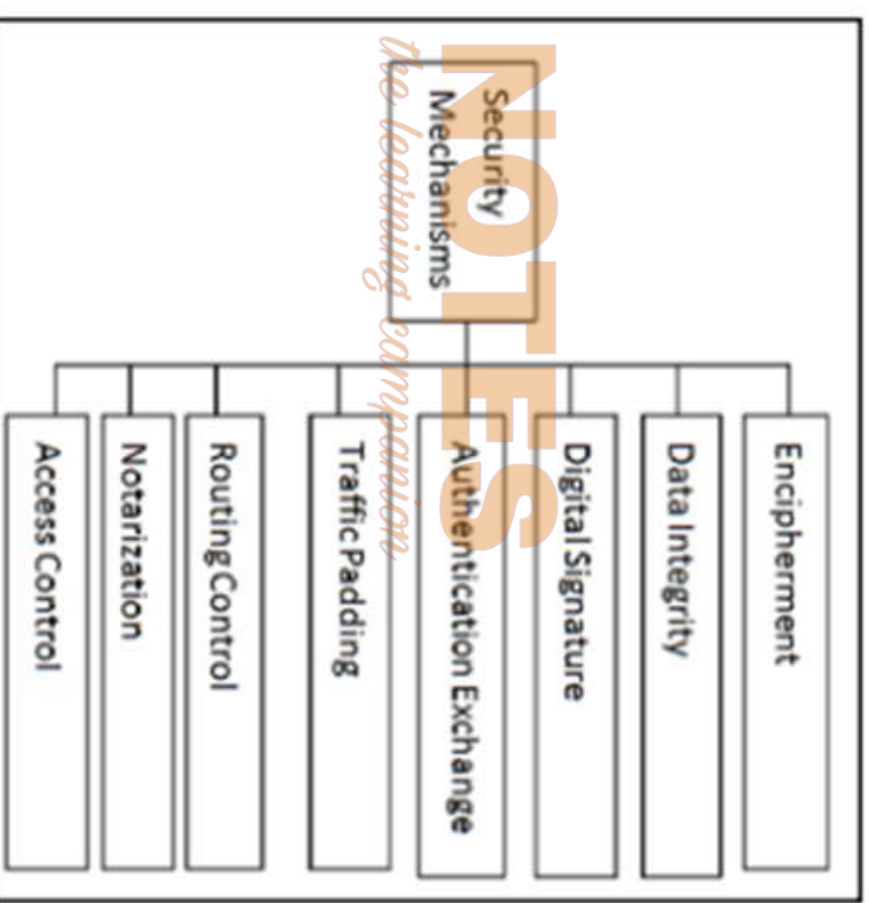


Fig. 4: Security Mechanisms



# Specific Security Mechanisms

- These may be incorporated into the appropriate protocol layer in order to provide some of the OSI security services. Some techniques for realizing security are listed here.

## 1. Encipherment

- This is the process of using mathematical algorithms to transform data into a form that is not readily intelligible.
- The transformation and subsequent recovery of the data depend on an algorithm and zero or more encryption keys.

**KTU NOTES**  
*the learning companion*

## 2. Digital Signature

- Data or cryptographic transformation of a data unit is appended to the data, so that the recipient of the data unit is convinced of the source and integrity of the data unit and this can also serve to protect the data against forgery (e.g., by the recipient).

### **3. Access Control**

- A variety of mechanisms are available that enforce access rights to resources.

### **4. Data Integrity**

- A variety of mechanisms may be used to assure the integrity of a data unit or stream of data units.

### **5. Authentication Exchange**

- This is a mechanism intended to ensure the identity of an entity by means of information exchange.

### **6. Traffic Padding**

- The insertion of bits into gaps in a data stream is called traffic padding. This helps to thwart traffic analysis attempts.

### **7. Routing Control**

- Routing control enables selection of particular physically secure routes for certain data transmission and allows routing changes, especially when a breach of security is suspected.

### **8. Notarization**

- This is the use of a trusted third party to assure certain properties of a data exchange.



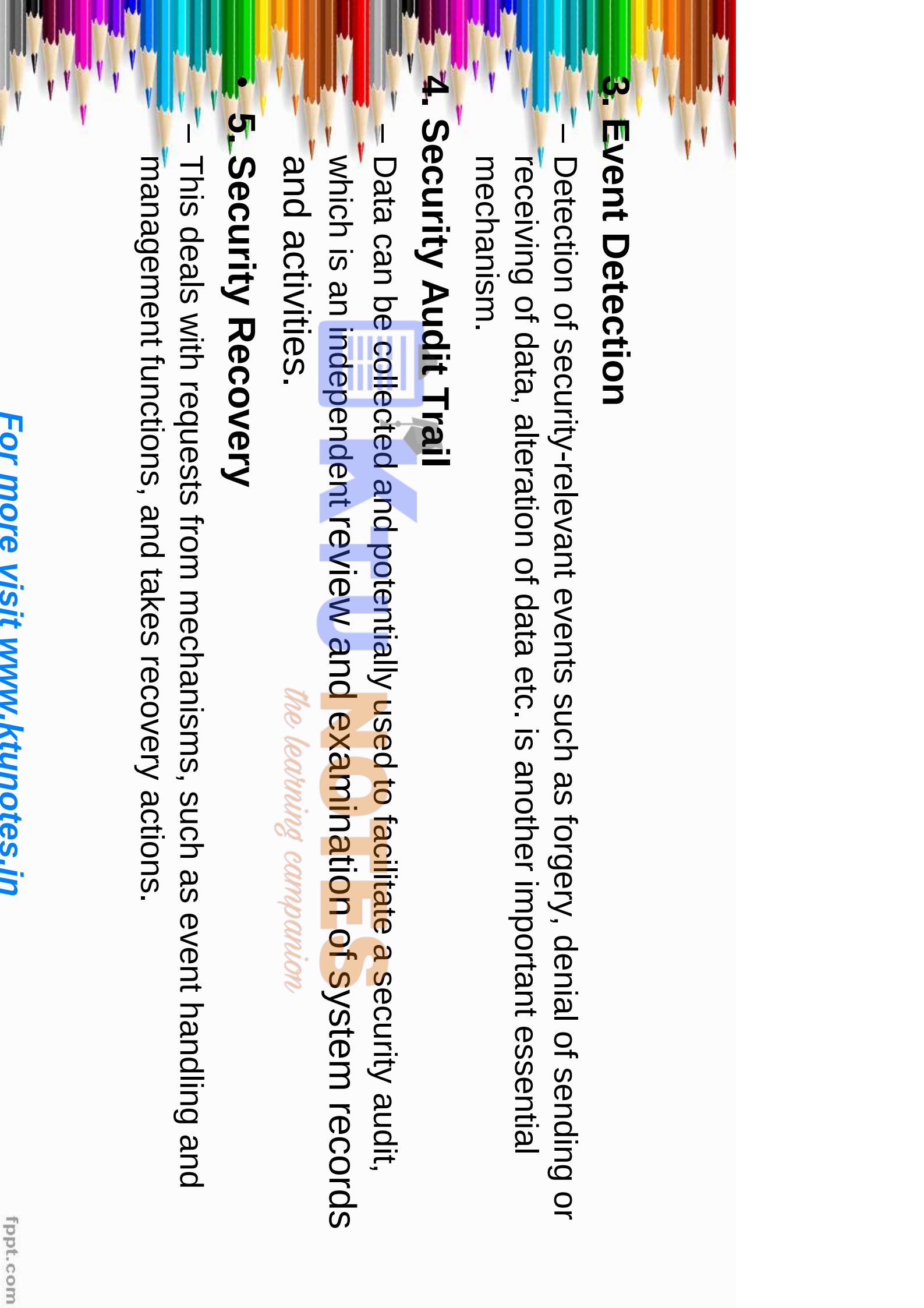
**KTU NOTES**

*the learning companion*



# Pervasive Security Mechanisms

- These are the mechanisms that are not specific to any particular OSI security service or protocol layer.
- **1. Trusted Functionality**
  - The process that which is perceived to be correct with respect to some criteria (e.g., as established by a security policy).
- **2. Security Label**
  - This is the technique of marking of a bound to a resource (which may be a data unit) that names or designates the security attributes of that resource



### 3. Event Detection

- Detection of security-relevant events such as forgery, denial of sending or receiving of data, alteration of data etc. is another important essential mechanism.

### 4. Security Audit Trail

- Data can be collected and potentially used to facilitate a security audit, which is an independent review and examination of system records and activities.

*the learning companion*

### • 5. Security Recovery

- This deals with requests from mechanisms, such as event handling and management functions, and takes recovery actions.

Table 1.4 Relationship Between Security Services and Mechanisms

| Service                      | Mechanism           |                      |                   |                   |                                 |                    |                    |                   |
|------------------------------|---------------------|----------------------|-------------------|-------------------|---------------------------------|--------------------|--------------------|-------------------|
|                              | Encrypt-<br>element | Digital<br>signature | Access<br>control | Data<br>integrity | Authenti-<br>cation<br>exchange | Traffic<br>padding | Routing<br>control | Notari-<br>zation |
| Peer entity authentication   | Y                   | Y                    |                   |                   | Y                               |                    |                    |                   |
| Data origin authentication   | Y                   | Y                    |                   |                   |                                 |                    |                    |                   |
| Access control               |                     |                      | Y                 |                   |                                 |                    |                    |                   |
| Confidentiality              | Y                   |                      |                   |                   |                                 |                    | Y                  |                   |
| Traffic flow confidentiality | Y                   |                      |                   |                   |                                 | Y                  | Y                  |                   |
| Data integrity               | Y                   | Y                    |                   | Y                 |                                 |                    |                    |                   |
| Nonrepudiation               |                     | Y                    |                   | Y                 |                                 |                    |                    | Y                 |
| Availability                 |                     |                      |                   | Y                 | Y                               |                    |                    |                   |

# Relation Between Security Services and Security Mechanisms

**Table 1.2** *Relation between security services and mechanisms*

| <i>Security Service</i> | <i>Security Mechanism</i>                                 |
|-------------------------|-----------------------------------------------------------|
| Data confidentiality    | Encipherment and routing control                          |
| Data integrity          | Encipherment, digital signature, data integrity           |
| Authentication          | Encipherment, digital signature, authentication exchanges |
| Nonrepudiation          | Digital signature, data integrity, and notarization       |
| Access control          | Access control mechanism                                  |